



SecurePress

AUDIT • ÉVIDENCES • CONFORMITÉ

SecurePress — Audit statique WordPress

Analyse, configuration et sécurisation
d'une plateforme WordPress

Mohamed Akram BENCHIHEB — Projet de fin d'études,
LNET Communication SARL • EMSI • 2025/2026



Périmètre : démonstration locale hors ligne, sans scan ni modification de production

COMPRENDRE • MESURER • SÉCURISER • DÉMONTRER

UNE APPROCHE BASÉE SUR LES PREUVES

DES SITES
PLUS SÛRS
DES DÉCISIONS
ÉCLAIRÉES



Source

Package WordPress local

C:\SecurePress\targets\
inet-telco-wordpress



Source vérifiée



Fichiers



Plugins



Thèmes



Configuration



Contenus



Analyse

Composants et vulnérabilités



22 composants indexés



10 constats analysés



2 critiques



Preuves



Traçabilité



Recommandations



Conformité



Configuration

Mesures de sécurité



Contrôles et durcissement



Politiques locales



Jeux de changements



Validation

Résultats et rapport



Contrôles exécutés



Écarts identifiés



Rapport d'évidence

WORDPRESS • SÉCURITÉ • CONFIANCE

REPÈRE : 1 CONTEXTE & PROBLÉMATIQUE

WordPress expose une surface étendue

- Cœur CMS, thèmes, plugins, code spécifique, base de données et hébergement
- Chaque dépendance peut modifier la surface d'attaque et le niveau de risque
- Analyse conduite sur une copie hors ligne anonymisée/préparée du scénario LNET TELCO
- Objectif : produire un diagnostic exploitable sans divulguer l'environnement réel



● Risque critique ● En attente de validation

ANALYSE SÉCURITÉ WORDPRESS

Le diagnostic doit rester qualifié

Une archive locale donne des preuves, pas tout l'état d'exécution

DES PREUVES
POUR DES DÉCISIONS
PLUS SÛRES

PREUVE
CONTEXTE
DÉCISION



Observation confirmée

Le composant est présent dans l'archive locale.

Preuve collectée



Risque potentiel

Le composant présente une version vulnérable ou une configuration à risque.

Analyse requise



Validation restante

L'activation, l'exposition et l'impact doivent être vérifiés dans l'environnement cible.

À confirmer



Plugin présent ≠ actif



Version vulnérable ≠ exploitable



Question : qualifier les risques et préparer des corrections reproductibles

Chaque conclusion sépare observation confirmée, risque potentiel et validation restante

REPÈRE : 2 CONCEPTION DE LA SOLUTION

La réponse suit les preuves

1



Collecter et qualifier les preuves disponibles dans l'archive

2



Inventorier cœur WordPress, thèmes, plugins, fichiers sensibles et composants spécifiques

3



Analyser configuration, versions, exposition probable et code personnalisé

4



Relier chaque constat à une correction, un contrôle et une limite de validation

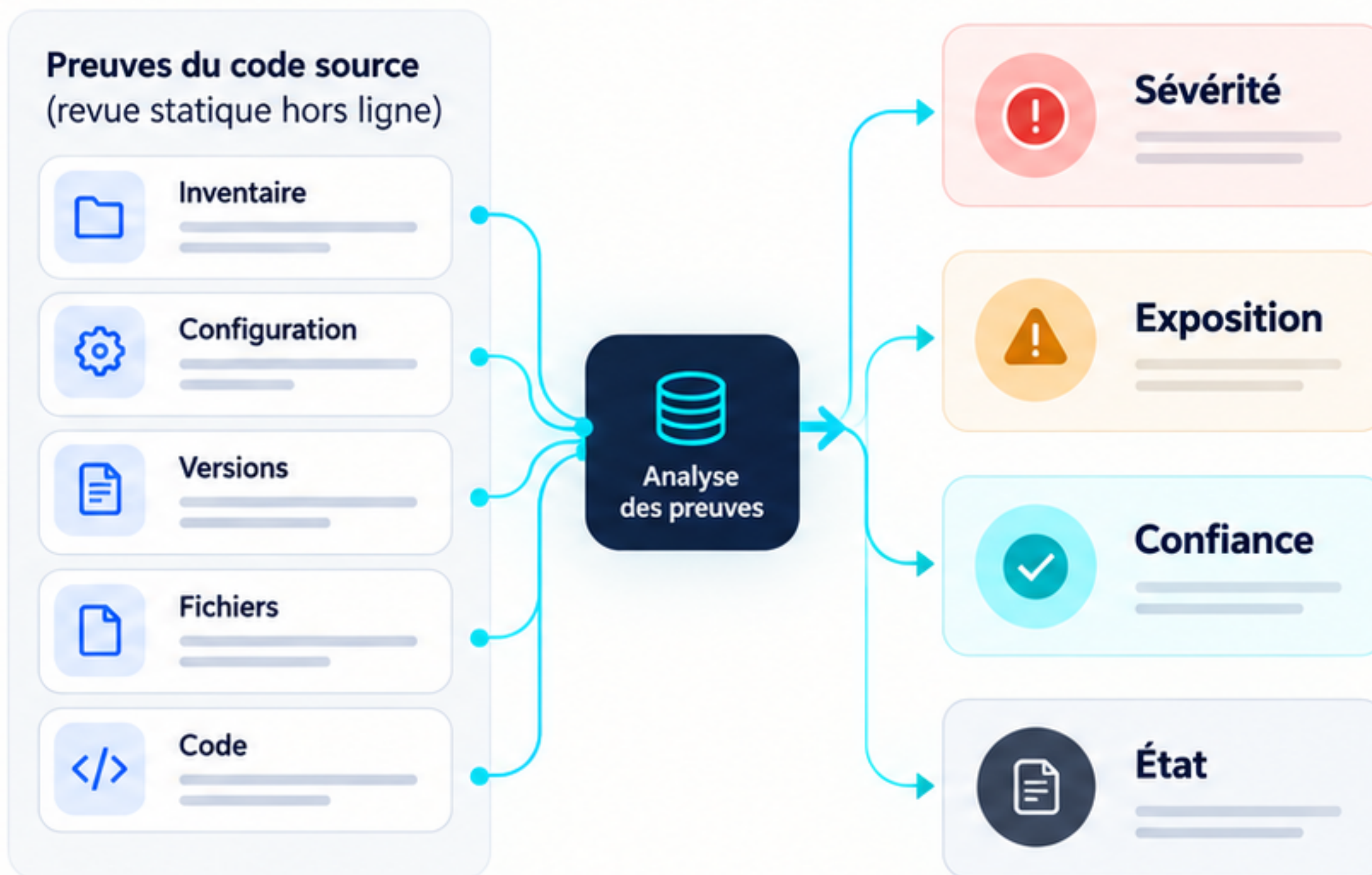


Repère : 2 Conception de la solution

La méthode évite la surinterprétation

- ✓ Approche alignée avec OWASP Top 10:2021, OWASP WSTG et NIST SP 800-115
- ✓ Revue statique hors ligne : inventaire, configuration, versions, fichiers et code
- ✓ Nuclei sert de référence de templates et de comparaison de versions, sans scan live démontré

Constat qualifié



Repère : 3 Architecture technique

Deux périmètres sont séparés

Une analyse complète, en local, sans aucun impact sur l'environnement de production.



Plateforme WordPress

Code source local à analyser, isolé de toute connexion externe.

-  **Navigateur**
-  **Thème**
-  **Cœur CMS**
-  **Plugins**
-  **Info Cards**
-  **Base MySQL-compatible**



Frontière explicite

Aucune communication vers la production.



Workflow SecurePress

Analyse locale et reproductible, dans un environnement isolé.



○ ——— **Traitement 100 % local** ——— ○

Des données qui restent sur votre poste. Une analyse en toute sécurité.



Aucune connexion production



Aucun scan réseau



Aucune modification cible



Démo / copie hors ligne

REPÈRE : 3 ARCHITECTURE TECHNIQUE

L'inventaire confirme le périmètre local

Des preuves
pour des décisions
plus sûres.

Archive applicative indexée

Cartographie des composants présents dans l'archive WordPress locale.

 Inventaire local**WordPress**

Cœur de l'application

WordPress 6.4.3

**Plugins**

17 répertoires de plugins

- akismet
- woocommerce
- litespeed-cache
- ...

**Thèmes**

4 thèmes identifiés

- astra
- twentytwentyfour
- twentytwentythree
- ...



WordPress

6.4.3



Astra

4.6.3



WooCommerce

8.4.0



Composants confirmés

17 répertoires de plugins
4 thèmes identifiés
dans l'archive applicative



Info Cards 1.0.2

bloc Gutenberg PHP, JSON, JavaScript/React et CSS

<?>

PHP

{ }

JSON



JavaScript/React



CSS



Limite de preuve

Export SQL absent
l'état runtime de la base ne peut pas être confirmé



Preuve locale · Composants détectés dans l'archive, sans exposition externe.

La source locale est vérifiée

Repère : 4 Implémentation & évaluation



Existence, accès et structure WordPress contrôlés avant l'analyse



Lecture progressive des fichiers, thèmes et plugins



Déverrouillage de la découverte uniquement après vérification

Chemin sélectionné :

C:\SecurePress\targets\lnet-telco-wordpress



Existence, accès et structure WordPress contrôlés avant l'analyse



Lecture progressive des fichiers, thèmes et plugins



Déverrouillage de la découverte uniquement après vérification



Simulation locale — aucune connexion production

REPÈRE : 4 IMPLÉMENTATION & ÉVALUATION

La découverte indexe sans inférer



L'indexation n'infère pas l'activation des plugins ou thèmes



Preuves, statuts et limites restent visibles à chaque étape



Découverte

Découverte : **22** composants indexés dans le package local



Package local

- wp-content
- wp-includes
- wp-admin



Indexation

22



Catalogue de composants

- Thèmes
- Plugins
- Composants core
- Autres



Analyse encadrée

- !
- !
- i
-



Analyse : 10 constats de démonstration — 2 critiques, 3 hauts, 3 moyens, 2 faibles/variables



2 critiques



3 hauts



3 moyens



2 faibles/variables

REPÈRE : 4 IMPLÉMENTATION & ÉVALUATION

Les risques prioritaires sont traçables

Constats qualifiés depuis les preuves locales

Chaque constat est relié à une preuve observable dans la copie locale et peut être vérifié sur la cible lors de l'étape de validation.



Des preuves aux actions

Une traçabilité complète pour prioriser les corrections et sécuriser durablement votre environnement WordPress.



critique

wp-config.php

wp-config.php : compte base de données root et mot de passe vide



élevé

wp-config.php

Clés et salts WordPress laissés aux valeurs d'exemple



durcissement

local archive

Durcissement manquant : DISALLOW_FILE_EDIT, FORCE_SSL_ADMIN, stratégie de mises à jour



à confirmer

local archive

XML-RPC, sauvegardes, permissions et modération : confirmation côté cible requise

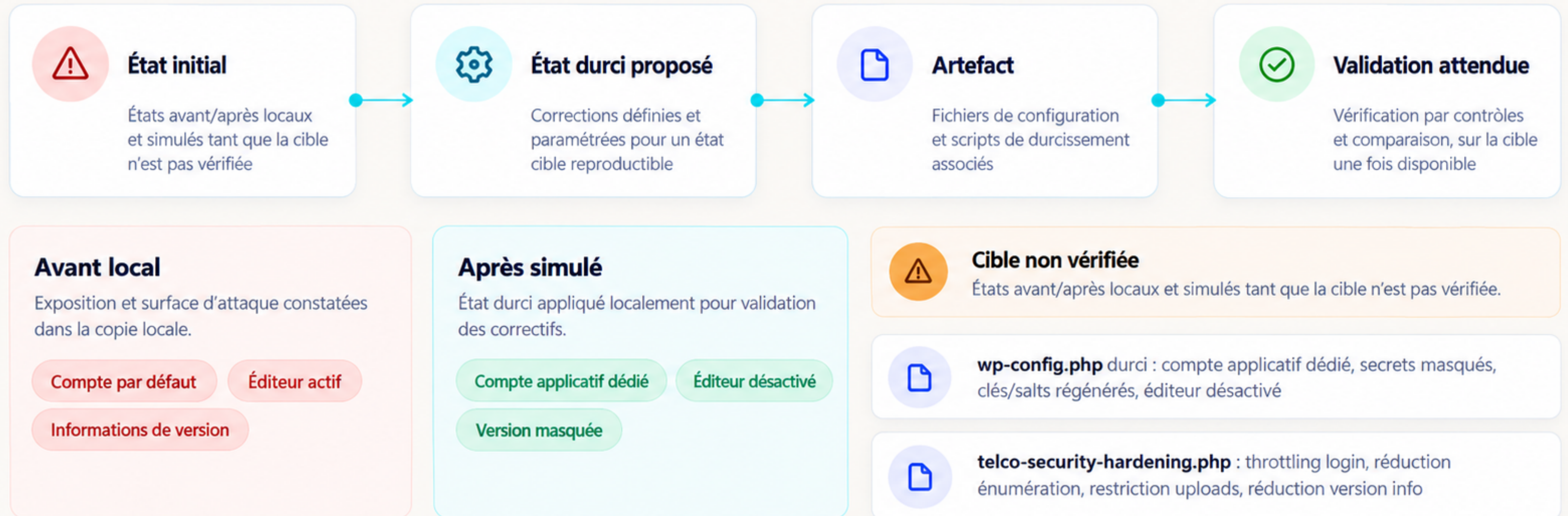


cible à confirmer

REPÈRE : 4 IMPLÉMENTATION & ÉVALUATION

Les corrections restent reproductibles

Chaque correction relie état initial, état durci proposé, artefact et validation attendue



Le résultat est utile mais limité

DES PREUVES
POUR DES SYSTÈMES
PLUS SÛRS



ANALYSER
COMPRENDRE
SÉCURISER
PROGRESSER

Repère : **4** Implémentation & évaluation

10 contrôles

- limitation des tentatives
- politique de téléversement
- éditeur fichier
- XML-RPC
- intégrité
- régression

10 contrôles



Simulation locale

 **5 échecs** de connexion
puis verrouillage de 15 minutes

 **shell.php bloqué,**
document.pdf et photo.jpg
autorisés

Simulation locale



Livrables

-  wp-config.php durci
-  mu-plugin
-  remediation-runbook.md
-  protocole de contrôles

Livrables



Posture pédagogique

42/100 → 82/100

 non assimilable à un score réel

Posture pédagogique



Contrôle local validé ≠ vérification sur l'environnement cible

MÊMES CONTRÔLES
AUTRE CONTEXTE
AUTRES RISQUES



La suite passe par une validation cible



SecurePress formalise un audit statique WordPress hors ligne, traçable et pédagogique



Preuves → inventaire → analyse → jeux de changements → contrôles → rapport



Non prouvé : déploiement production, WP-CLI réel, validation TLS/headers, scan dynamique post-correction, contre-audit cible



Prochaines étapes : préproduction, DAST autorisé, durcissement .htaccess, maintenance continue et automatisation DevSecOps



La conclusion reste conditionnée par une validation autorisée sur l'environnement cible